

Vulnerability Assessment Report

E-commerce Database Server | Qualitative Risk Assessment | NIST SP 800-30 Rev. 1

Assessment period June 20XX to August 20XX	Assessment focus Current access controls for a publicly accessible database server	Method Qualitative risk assessment guided by NIST SP 800-30 Rev. 1
---	---	---

System Description

The server hardware consists of a powerful CPU processor and 128 GB of memory. It runs the latest version of a Linux operating system and hosts a MySQL database management system. The server is configured with a stable network connection using IPv4 addresses and interacts with other servers on the organization network. Security measures currently include SSL/TLS encrypted connections, but the database server has remained publicly accessible since the company's launch three years ago.

Scope

The scope of this vulnerability assessment relates to the current access controls of the publicly accessible database server. The assessment covers a three-month period from June 20XX to August 20XX and focuses on confidentiality, integrity, and availability risks to the data and services hosted on the server. Physical security of the facility and unrelated IT systems are outside the scope of this report. NIST SP 800-30 Rev. 1 is used to guide the risk identification, likelihood scoring, severity scoring, and remediation recommendations.

Purpose

The purpose of this vulnerability assessment is to evaluate the risk created by keeping the company's remote MySQL database server open to the public internet. The server is valuable because employees rely on it to query customer and business data needed for sales, marketing, and daily e-commerce operations. Securing this data is important because unauthorized access could expose sensitive information, disrupt business processes, and damage customer trust. If the server were disabled or compromised, employees could lose access to critical records and the company could experience operational delays, financial loss, and reputational harm.

Risk Assessment

Risk was calculated using a qualitative scoring model: Likelihood x Severity = Risk. Scores range from 1 to 3 for likelihood and severity, producing an overall risk score from 1 to 9.

Threat Source	Threat Event	Likelihood	Severity	Risk
Outsider / hacker	Obtain sensitive information via exfiltration from the publicly accessible database server.	3	3	9
Competitor or malicious external group	Conduct reconnaissance and surveillance against the public database server to discover weaknesses for future exploitation.	3	2	6
Standard user, customer, or compromised account	Alter or delete critical information if database access controls are weak or misconfigured.	2	3	6

Risk Rating Notes

High risk: 7-9	Immediate remediation is recommended because the threat could cause serious operational, financial, or reputational impact.
Moderate risk: 4-6	Planned remediation is recommended because the threat could significantly affect business operations or data protection if left untreated.
Low risk: 1-3	Monitor and address through routine security maintenance where appropriate.

Approach

This assessment used a qualitative risk approach based on the system description, scope, known exposure of the database server, and threat categories described in NIST SP 800-30 Rev. 1. The selected risks focus on realistic events for a public-facing database: data exfiltration, reconnaissance, and unauthorized modification or deletion of business information. Likelihood scores were based on the ease with which threat sources could reach the exposed server and the amount of time the server has been publicly accessible. Severity scores were based on the potential impact to confidentiality, integrity, availability, customer trust, and business continuity. This assessment is limited by the scenario information provided and does not include live vulnerability scanning, log review, penetration testing, or direct validation of firewall and access control configurations.

Remediation Strategy

The highest priority is to remove direct public access to the MySQL database server and place it behind layered network controls such as a firewall, private subnet, VPN or secure gateway, and IP allowlisting for approved employee connections. The organization should enforce the principle of least privilege by limiting database permissions to only the users, roles, and applications that require access, while requiring multi-factor authentication for administrative access. The company should also implement an Authentication, Authorization, and Accounting framework with centralized logging, regular access reviews, and monitoring alerts for suspicious queries, failed logins, unusual data transfers, and configuration changes. To reduce the impact of potential compromise, the organization should maintain tested backups, apply timely Linux and MySQL security patches, encrypt sensitive data at rest and in transit, and document incident response procedures for database-related events. These controls reduce the risk of unauthorized data access, data modification, service disruption, and delayed incident detection.

Recommended Remediation Roadmap

Priority	Action	Risk Addressed	Expected Security Benefit
Immediate	Remove public database exposure. Restrict access through firewall rules, VPN, private networking, and IP allowlisting.	Exfiltration, reconnaissance, unauthorized access	Reduces the attack surface and prevents untrusted internet sources from directly reaching the database.
Immediate	Review database users, roles, and permissions. Enforce least privilege and remove unused or excessive access.	Data alteration/deletion, privilege misuse	Limits the damage caused by compromised or unnecessary accounts.
Short term	Enable MFA for privileged access and use centralized authentication for administrator accounts.	Account compromise	Makes unauthorized administrative access significantly harder.
Short term	Enable database, firewall, and operating system logging with alerting for unusual activity.	Delayed detection, reconnaissance, suspicious queries	Improves visibility and shortens detection and response time.
Ongoing	Patch Linux and MySQL, test backups, review access regularly, and update incident response procedures.	Known vulnerabilities, data loss, recovery delays	Improves resilience and supports business continuity after a security event.

Conclusion

The database server is a critical business asset because it supports employee access to customer and e-commerce data. Its public accessibility creates a significant vulnerability that increases the likelihood of unauthorized access, reconnaissance, and data compromise. By restricting public access, enforcing least privilege, strengthening authentication, improving monitoring, and maintaining reliable backups, the organization can substantially reduce the risk to business operations and customer trust.

References

National Institute of Standards and Technology. Guide for Conducting Risk Assessments, Special Publication 800-30 Revision 1. Adapted course material used for this activity.